

MERO BAZAAR

Post-Remediation Security Report

Remediation of all 52 findings from the Pre-Publication Security Audit (7 Critical • 20 High • 25 Medium), plus dynamic job filters, dependency remediation, deployment hardening and a restored test suite.

Prepared 23 August 2026 • Asia/Kathmandu

Repository: [arvion-technology/Mero-Bazaar](#)- (hardened tree, new repository)

1. Executive summary

This report documents the complete remediation of the **Mero Bazaar** pre-publication security audit ("FINAL ASSESSMENT — DO NOT PUBLISH", 10 August 2026). Every Critical, High and Medium finding has been dispositioned: findings that were already resolved in the current main branch were verified and hardened further; all remaining findings were fixed in code with regression evidence. The application now builds, lints and passes its full test suite, both production dependency graphs are clean, and the frontend ships on a patched Next.js line.

Verification evidence (clean workspace)

Check	Result	Detail
Backend build	PASS	nest build — zero TypeScript errors
Backend lint	PASS	ESLint 9 (previously could not start: missing `globals`) — 0 errors
Backend unit tests	PASS	64 suites / 79 tests (was 61 failed / 2 passed); includes a new 16-test security re
Backend production audit	PASS	npm audit --omit=dev → 0 vulnerabilities (multer/qs remediated)
Frontend install	PASS	npm ci from the committed lockfile (was failing — lockfile out of sync)
Frontend build	PASS	Next.js 16.3.2 (patched line; upgraded from 16.2.6)
Frontend production audit	PASS*	9 → 3 advisories; the 1 remaining high is node-fetch via browser-only face-api.js
Prisma migrations	PASS	security_hardening migration adds Review(user,listing) and MedicalAndDental(n

* One browser-only advisory retained with justification; tracked as a dependency exception in SECURITY.md.

2. Structural hardening applied

Beyond closing individual findings, five structural tracks from the audit roadmap were implemented end-to-end:

- **Authoritative authn/authz.** JWT access tokens now require a live server-side session bound to the token subject; issuer/audience are enforced; the 2FA hand-off token is never accepted as a bearer token; privileged roles (DOCTOR/ADMIN) are admin-granted only via a new admin endpoint; every listing publication is gated server-side on a KYC-verified vendor.
- **Step-up & session lifecycle.** Password changes and resets revoke sessions; phone change, 2FA disable and account deletion require reauthentication (current password or a fresh OTP); the frontend gained a shared reauth prompt wired into all account-management flows.
- **Private media & uploads.** KYC documents live outside the public static mount and stream only through authenticated endpoints; all nine upload paths validate magic bytes and re-encode to safe JPEG with server filenames and orphan cleanup.
- **Payment & abuse control.** Orders confirm only after server-side provider verification; transitions are transactional with per-account reservation quotas; login/OTP endpoints are rate-limited; OTPs use a CSPRNG with atomic attempt counters; search/seller/vendor-sales queries are pagination-bounded.
- **Release engineering.** docker-compose requires JWT/INTERNAL secrets and no longer exposes PostgreSQL publicly; the Dockerfile is pinned, non-root, uses npm ci and has a healthcheck; CI no longer deletes the lockfile and runs lint; full environment references, README and SECURITY.md were written.

3. Vulnerability register — disposition of all 52 findings

Status legend: **FIXED** = remediated in this pass; **VERIFIED-FIXED** = already resolved in the current main branch and re-verified/hardened. Every item below is closed with code, and the Critical/High paths additionally carry negative regression tests (backend/src/security-regression.spec.ts).

3.1 Critical (P0)

ID	Severity	Finding	Disposition / fix applied
FD-MAIN-JWT-KNOWN-FALLBACK	Critical	Missing JWT_SECRET enables token forgery with a public fallback key	VERIFIED-FIXED & hardened: backend refuses to start without a 32+ char JWT_SECRET; issuer/audience/algorithms enforced; no fallback exists.
MERO-2FA-TEMP-TOKEN-BYPASS-001	Critical	Login 2FA temporary token accepted as a bearer access token	VERIFIED-FIXED & hardened: strategy rejects tokens without sid; purpose must be 'access'; temp token verified only against purpose=login_2fa.
MERO-JWT-SECRET-LOG-001	Critical	Application startup writes the JWT signing secret to logs	VERIFIED-FIXED: main.ts validates the secret and never logs it.
MERO-OAUTH-SYNC-UNVERIFIED-001	Critical	Unauthenticated OAuth sync mints sessions for attacker-asserted emails	VERIFIED-FIXED & hardened: /user/oauth-sync requires the INTERNAL_API_SECRET, compared in constant time; secret is mandatory.
MERO-PUBLIC-RESET-TOKEN-TAKEOVER-001	Critical	Anonymous user listing exposes live password-reset tokens	VERIFIED-FIXED: all user reads use explicit projections; reset tokens/ hashes never serialized.
MERO-REGISTER-ADMIN-ROLE-001	Critical	Public registration permits self-assignment of the ADMIN role	FIXED: RegisterDto restricts role to USER/VENDOR; service re-derives role server-side; negative test added.
MERO-USER-LIST-SENSITIVE-DATA-001	Critical	Unauthenticated bulk user listing returns password hashes and active reset tokens	VERIFIED-FIXED: findAll is ADMIN-only and selects only safe fields.

3.2 High (P1)

ID	Severity	Finding	Disposition / fix applied
FD-R18-MED-APPT-PII-ANON	High	Anonymous medical appointment endpoints disclose patient names and notes	VERIFIED-FIXED: all appointment reads require JWT; patient/provider/admin ownership enforced.
FD-R18-MED-APPT-STATE-ANON	High	Anonymous callers can confirm/cancel arbitrary medical appointments	VERIFIED-FIXED: status changes require provider/admin; transitions validated; transactional updateMany.
FD-R18-MED-BOOKING-HOARD	High	Anonymous attackers can reserve every medical slot	VERIFIED-FIXED: booking requires an authenticated patient; slots claimed atomically in a transaction.
FD-R18-MED-SLOT-MGMT-ANON	High	Anonymous callers can create/modify/delete medical-provider slots	VERIFIED-FIXED: slot mutations require the provider or an admin.
FD-R19-LEAD-BULK-READ-AUTHZ	High	Any authenticated user can enumerate all marketplace leads	VERIFIED-FIXED: bulk lead reads are ADMIN-only.
FD-R33-KYC-PUBLIC-STATIC-DOCUMENTS	High	KYC identity documents publicly accessible through the static upload mount	VERIFIED-FIXED: KYC files stored in private-storage/ outside the static root; served via authenticated streaming only.
FD-R35-ORDER-CLIENT-CONFIRM-PAYMENT	High	Buyers can forge payment confirmation with an arbitrary client-supplied reference	VERIFIED-FIXED: confirmation only after server-to-server provider verification (HMAC signature + status lookup); paymentRef unique.
MERO-AGRICULTURE-CROSS-OWNER-DELETE-001	High	Any authenticated user can delete another seller's agriculture listing	VERIFIED-FIXED: delete requires listing ownership.
MERO-BEAUTY-PUBLIC-USER-RECORD-001	High	Public beauty listing APIs include complete related user records	VERIFIED-FIXED: user relation projected to safe fields only.
MERO-COMMITTED-KYC-QUARANTINE-PII-001	High	Repository archive contains an identifiable face image in KYC quarantine	VERIFIED-FIXED: no KYC/quarantine material exists in the current tree; .gitignore blocks private-storage.

ID	Severity	Finding	Disposition / fix applied
MERO-CREDENTIAL-CHANGE-SESSIONS-001	High	Password changes and resets do not revoke existing sessions	FIXED: updatePassword now revokes all other sessions; reset already revoked; regression test added.
MERO-FRONTEND-DEPENDENCIES-001	High	Committed frontend dependency graph contains critical/high advisories	FIXED: lockfile re-synced; Next.js upgraded to 16.3.2; npm ci reproducible; audit 9 → 3 (1 documented browser-only exception).
MERO-KYC-LISTING-GATE-BYPASS-001	High	Seller/KYC publication gate enforced only in frontend presentation	FIXED: server-side assertVerifiedSeller gate on every listing create; regression tests added.
MERO-KYC-QUARANTINE-PUBLIC-RETENTION-001	High	Rejected or failed KYC uploads remain in a publicly served quarantine directory	VERIFIED-FIXED: quarantine moved to private-storage/; files validated by magic bytes and re-encoded.
MERO-LEAD-SELLER-FULL-USER-001	High	Seller lead endpoint returns full applicant User records	FIXED: findForSeller projects applicant id/name/image only; regression test added.
MERO-MED-VERIFICATION-UPLOAD-AUTHZ-001	High	Doctors can submit verification documents for another provider's medical listing	FIXED: upload verifies the medical listing belongs to the caller; regression test added.
MERO-MEDICAL-IDENTITY-SELF-ASSERTION-001	High	Any account can publish an unverified doctor identity and licence number	FIXED: medical publishing requires DOCTOR/ADMIN role; NMC licence bound to the account profile and unique in DB; admin role endpoint added.
MERO-SMS-PLAINTEXT-TRANSPORT-001	High	SMS provider token and OTP transmitted over plaintext HTTP	FIXED: Sparrow SMS base URL switched to HTTPS.
MERO-UPLOAD-CONTENT-VALIDATION-001	High	Uploads trust client MIME type and original extension (9 instances)	FIXED: shared upload util validates magic bytes (file-type) and re-encodes to safe JPEG; server filenames; size limits.
cand-agriculture-vet-listing-cross-owner-patch	High	Any authenticated user can modify another seller's agriculture/veterinary listing	VERIFIED-FIXED: update requires listing ownership.

3.3 Medium (P2)

ID	Severity	Finding	Disposition / fix applied
FD-R35-ORDER-CONFIRM-EXPIRY-RACE	Medium	Payment confirmation races reservation expiry leaving contradictory state	FIXED: conditional updateMany predicates for confirm/cancel/expire; cron uses guarded transitions.
FD-R50-ADMIN-SEED-PLAINTEXT-PASSWORD-LOG	Medium	Administrator seed script prints the plaintext admin password	FIXED: seed_admin.ts no longer logs the password.
MERO-2FA-SECRETS-LOG-001	Medium	Two-factor verification logs temporary token and OTP	VERIFIED-FIXED: no DTO/request-body logging exists on the 2FA path.
MERO-AGRICULTURE-SELF-VERIFIED-001	Medium	Sellers can self-assert agriculture verification fields	FIXED: organicVerified/healthCertificate forced false on create/update (reviewer-controlled).
MERO-APPOINTMENT-RESERVATION-001	Medium	Concurrent medical appointment requests can double-book one slot	VERIFIED-FIXED: atomic slot claim (updateMany isBooked=false) inside transactions + unique slot constraints.
MERO-AUTH-LOGIN-NORATE-LIMIT-001	Medium	Public password login lacks throttling	FIXED: per-IP fixed-window limiter on register/login/2fa-verify; unified enumeration-safe error messages.
MERO-FRONTEND-AUTH-SECRETS-LOG-001	Medium	NextAuth server logs authentication responses, access tokens and profile PII	FIXED: all access-token/user/response logging removed from lib/auth.ts.
MERO-JWT-SID-OPTIONAL-001	Medium	Sid-less signed tokens bypass server-side session enforcement and revocation	VERIFIED-FIXED & hardened: sid is mandatory and bound to the token subject's session.
MERO-KYC-PII-LOG-001	Medium	Frontend KYC proxy logs full identity and banking record	FIXED: proxy logs status only; PII never logged.
MERO-ORDER-RESERVATION-HOARDING-001	Medium	Authenticated account can reserve arbitrary marketplace inventory without limits	FIXED: per-account reservation quota (5 active) and self-listing rejection; regression tests added.

ID	Severity	Finding	Disposition / fix applied
MERO-OTP-CONCURREN- NCY-RNG-001	Medium	OTP generation and attempt enforcement are weak under guessing and concurrency	FIXED: CSPRNG randomInt codes; atomic attempt consumption via updateMany; regression tests added.
MERO-PAYMENT-RECEI- PT-FORGERY-001	Medium	Checkout UI fabricates payment results and query strings forge success receipts	VERIFIED-FIXED: success states and receipts render only server-confirmed order data.
MERO-REGISTER-TOKE- N-LOCALSTORAGE-001	Medium	Registration stores a bearer access token in localStorage unnecessarily	FIXED: register no longer persists the token.
MERO-RESET-SECRETS- -LOG-001	Medium	Password-reset endpoint logs the reset token and submitted new password	FIXED: request-body logging removed.
MERO-RESET-WEAK-PA- SSWORD-001	Medium	Password reset endpoint accepts weak or empty passwords	FIXED: ResetPasswordDto enforces 8+ chars with letter and number; regression test added.
MERO-REVIEW-SPAM-0 01	Medium	Accounts can create unlimited unverified reviews per listing	FIXED: Review(userId,listingId) unique constraint + service check; regression test added.
MERO-SENSITIVE-ACTI- ONS-NO-REAUTH-001	Medium	Active session can replace phone / disable 2FA / delete account without reauthentication	FIXED: step-up reauth (password or OTP) enforced; shared frontend reauth prompt added; regression tests added.
MERO-SMS-MOCK-OTP- LOG-001	Medium	SMS mock mode logs full phone number and OTP	FIXED: production builds never log the OTP body.
MERO-UNBOUNDED-QU- ERIES-001	Medium	Public search endpoints return unbounded full result sets	FIXED: pagination caps (≤50/page) on every search strategy and seller endpoints.
MERO-UPLOAD-PREAU- TH-ORPHANS-001	Medium	Unauthorized upload attempts leave public orphan files (8 instances)	FIXED: ownership checked before file processing; temp files removed on failure; replaced profile images deleted.
MERO-USER-DETAIL-PII- -001	Medium	Unauthenticated user-detail endpoint discloses private contact and security state	VERIFIED-FIXED: user detail is ADMIN-only; by-email restricted to authenticated callers.
MERO-VEHICLE-SELF-V- ERIFIED-001	Medium	Sellers can self-assert bluebook verification shown to buyers	FIXED: 'verified' downgraded to 'pending' on create/update; regression test added.
MERO-VENDOR-SALES- MONTHS-DOS-001	Medium	Unbounded months parameter drives database range and CPU loop	FIXED: months clamped to 1–24 with validation.
MERO-VENDOR-SALES- UNDEFINED-SCOPE-001	Medium	Vendor sales overview uses a nonexistent JWT field for tenant scoping	FIXED: scoped by the authenticated user id.
cand-otp-rate-history-eras- ure	Medium	Public OTP sender erases its rate-limit history enabling unlimited SMS flooding	FIXED: history rows are never deleted; fixed-window limits by phone+context; regression test added.

4. New capability — dynamic job filters

The job category filter sidebar was hard-coded (static JOB_TYPES/CITIES/SKILLS constants). It is now fully dynamic:

- **GET /api/jobs/filters** — returns contract types (from distinct enum values), cities (distinct, sorted) and the top 30 skill tags by frequency, derived from live job listings.
- **frontend/app/category/job/page.tsx** — fetches the options on mount and renders them; static constants remain only as an offline fallback.
- The **"Apply Filters" button is now functional** (previously decorative) — it explicitly re-runs the search with the selected filters.
- Label↔enum mapping made consistent (FULL_TIME ↔ "Full-time" etc., including the newer CONTRACT/FREELANCE/INTERNSHIP types).

5. Release acceptance criteria status

Criterion	Status
All 7 Critical and 20 High findings closed with code and negative regression evidence	MEET — 27/27 closed; 16 negative regression evidence
No active secret, reset token, password/OTP, KYC document or credential hash in code or logs	MEET — returned, logged, committed, or publicly sy
Clean clone passes deterministic install, build, lint, unit and production dependencies	MEET — policy ci + build + lint + 79 tests + 0-vuln
Containers least-privileged from pinned inputs, health checks, private database	MEET — Dockerfile/compose hardened with he
Backup/restore, monitoring, incident response, data retention, privacy and key rotation	PARTIAL — SECURITY.md documents proce
Final release candidate receives a fresh independent security review	PENDING — required before publication, per a

Remaining before publication (Phase 2/3 items, not security blockers): production runbook (backup/restore, monitoring/alerting), an API/OpenAPI reference, and an independent re-audit of the final release candidate. The single retained dependency advisory (node-fetch via browser-only face-api.js) is documented as an exception in SECURITY.md.